

TITLE OF THE PROJECT:

“Design And Apply Context-Aware Access Controls Based On User Identity, Device Posture, Location, And Application Risk”

INTRODUCTION

In the modern digital era, organizations rely heavily on web applications and online platforms to manage data, provide services, and communicate with users. As technology advances, the number of cyber threats and security attacks targeting web applications is also increasing rapidly. Attackers continuously search for vulnerabilities in systems to gain unauthorized access to sensitive information, disrupt services, or exploit security weaknesses.

Traditional security models mainly rely on username and password authentication to control access to systems. However, these methods are no longer sufficient because attackers can easily compromise passwords through phishing attacks, brute-force attacks, or other hacking techniques. Therefore, organizations must adopt more advanced security approaches to protect their systems and data.

Context-aware access control is a modern security approach that evaluates multiple factors before granting access to applications or resources. Instead of relying only on user credentials, the system also considers contextual information such as the user's identity, the device being used, the user's location, and the risk level of the requested application. By analyzing these factors together, the system can make intelligent decisions about whether to allow, restrict, or deny access.

This project focuses on studying and implementing context-aware access control mechanisms to improve the security of web applications. It also explores common web application vulnerabilities such as Cross-Site Scripting (XSS), SQL Injection, Broken Authentication, and Security Misconfiguration. Understanding these vulnerabilities helps in identifying security weaknesses and implementing effective security measures to prevent attacks.

In addition, the project highlights the importance of security monitoring systems such as Security Operations Centers (SOC) and Security Information and Event Management (SIEM) tools that help organizations detect and respond to cyber threats in real time. Overall, this

project aims to enhance the understanding of modern cybersecurity techniques and demonstrate how context-aware access control can strengthen the security of web applications and protect sensitive digital resources.

LIST OF TEAMMATES

S No	Name	College	Contact
1	ABINAYA S	Michael Job College	s.abinaya20112002@gmail.com
2	ARUNA JESINTHA W C	Michael Job College	arunajesintha5@gmail.com
3	DHARSHANA L	Michael Job College	lakshmanasamydharshana@gmail.com
4	JANAKI M	Michael Job College	janaki1501@gmail.com

ABSTRACT

With the rapid growth of web applications and online services, protecting digital systems from cyber threats has become a major challenge for organizations. Traditional security methods that rely only on usernames and passwords are no longer sufficient to protect sensitive data. Attackers often exploit vulnerabilities in web applications to gain unauthorized access, steal information, or disrupt services.

This project focuses on designing and applying context-aware access control mechanisms based on user identity, device posture, location, and application risk. The main objective is to improve the security of web applications by evaluating multiple contextual factors before granting access to resources. By using this approach, organizations can reduce security risks and prevent unauthorized access to sensitive systems.

The project also studies common web application vulnerabilities such as Cross-Site Scripting (XSS), SQL Injection, Broken Authentication, and Security Misconfiguration. These vulnerabilities are analysed to understand how attackers exploit them and how proper security

practices can prevent such attacks. In addition, vulnerability scanning tools like Nessus are used to identify security weaknesses in systems and provide recommendations for mitigation.

Furthermore, the project explores the role of Security Operations Center (SOC) and Security Information and Event Management (SIEM) systems in monitoring network activities and responding to cyber threats. Overall, this project highlights the importance of modern cybersecurity techniques and demonstrates how context-aware access control can enhance system security and protect digital resources from potential threats.

USE CASE SCENARIOS

Scenario 1: Student Access to Online Learning Portal

A university student wants to access the online learning portal to download course materials and submit assignments. The student logs in from a personal laptop connected to a home Wi-Fi network. The system verifies the student's identity using login credentials and checks the device security status. Since the student is accessing a low-risk academic resource from a known location, the system grants access without additional restrictions.

Output:

- ❖ Student successfully authenticated
 - ❖ Access granted to course materials and assignment portal
 - ❖ No additional verification required
-

Scenario 2: Employee Access from an Unrecognized Device

An employee attempts to log in to the organization's internal application from a new device that has never been used before. The system detects that the device is not registered in the organization's device management system. Because of this unusual device activity, the system requests additional verification before granting access.

Output:

- ❖ User identity verified using multi-factor authentication (MFA)
- ❖ Device flagged as unrecognized

- ❖ Access granted only after additional security verification
-

Scenario 3: Access to Confidential Data from a Restricted Location

A staff member attempts to access confidential company documents while traveling abroad. The system detects that the login attempt is coming from a foreign location that is considered high risk. Although the user credentials are valid, the system applies additional security restrictions.

Output:

- ❖ User authentication successful
 - ❖ Location detected as high risk
 - ❖ Access limited to view-only mode
 - ❖ Security alert generated for monitoring
-

Scenario 4: Multiple Failed Login Attempts

A user account experiences several failed login attempts within a short period of time. The system detects this suspicious behavior and assumes it may be a brute-force attack. To protect the account, the system temporarily locks the account and notifies the user.

Output:

- ❖ Multiple failed login attempts detected
 - ❖ Account temporarily locked
 - ❖ Security notification sent to the user and administrator
-

Scenario 5: Access to High-Risk Application from Public Wi-Fi

A user attempts to access a financial application while connected to public Wi-Fi in a coffee shop. The system detects that the network is not secure and identifies it as a high-risk connection. Instead of blocking access completely, the system enforces additional security measures.

Output:

- ❖ User identity successfully authenticated
- ❖ Public network detected as insecure
- ❖ Additional verification required before access
- ❖ Sensitive features restricted for security

Stage 1

Title:

“Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk.”

OVERVIEW:

In today’s digital world, organizations depend heavily on web applications and online systems to store and manage important information. With the increasing use of internet-based services, the risk of cyber threats and attacks has also increased. Hackers often try to exploit vulnerabilities in web applications to gain unauthorized access to sensitive data. Therefore, it is very important to implement strong security mechanisms to protect systems and user information.

The main idea of this project is to design and apply context-aware access control mechanisms to improve the security of web applications. Context-aware access control means that access to systems or applications is granted based on multiple factors such as user identity, device posture, location, and the risk level of the application. Instead of relying only on username and password authentication, this method evaluates several security parameters before allowing users to access resources.

In this project, we analyse common web application vulnerabilities such as Cross-Site Scripting (XSS), SQL Injection, Broken Authentication, and Security Misconfiguration. Understanding these vulnerabilities helps in identifying security weaknesses in applications and implementing proper solutions to prevent attacks.

The project also highlights the importance of modern security monitoring systems such as Security Operations Centre (SOC) and Security Information and Event Management (SIEM), which help organizations detect and respond to cyber threats effectively. Overall, this project focuses on understanding web application security and implementing better access control mechanisms to protect systems from potential cyberattacks.

LIST OF VULNERABILITY

S No	Vulnerability Name	CWE No
1	Cross-Site Scripting (Stored)	CWE-79
2	Broken Access Control	CWE-284
3	SQL Injection	CWE-89
4	Broken Authentication	CWE-287
5	Insecure Direct Object Reference	CWE-639
6	Security Misconfiguration	CWE-16
7	Cross-Site Request Forgery (CSRF)	CWE-352
8	Cleartext Transmission of Sensitive Information	CWE-319
9	Clickjacking	CWE-1021
10	Web Server Allows Password Auto-Completion	CWE-310

Report:

1. Vulnerability Name: Cross-Site Scripting (Stored)

CWE: 79

OWASP Category: A05:2025 – Injection

Description

Stored Cross-Site Scripting (XSS) is a vulnerability that occurs when a web application stores malicious scripts inside the server database and later executes them in users' browsers. This typically happens when input fields such as comments, search boxes, or feedback forms do not properly validate user input. An attacker can insert JavaScript code that gets saved in the application. When other users visit the affected page, the browser executes the script automatically.

The injected script runs with the same permissions as the web application, allowing attackers to manipulate the page content or capture sensitive information. Because the malicious code is stored permanently, every user who accesses the page may be affected.

Business Impact

Stored XSS attacks can cause serious damage to an organization. Attackers may steal user session cookies, capture login credentials, or redirect users to malicious websites. In some cases, attackers can perform actions on behalf of legitimate users without their knowledge. If the affected account belongs to an administrator, the attacker may gain higher privileges and compromise the entire system. This can result in data leakage, financial losses, and damage to the organization's reputation.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/search.php?test=query>

Steps to Reproduce

- Open the vulnerable website in a browser

<http://testphp.vulnweb.com>

- Navigate to the search field in the website
- Enter the following script in the search box

```
<script>alert('XSS')</script>
```

- Submit the search request

➤ If the site is vulnerable, a JavaScript alert popup will appear in the browser.

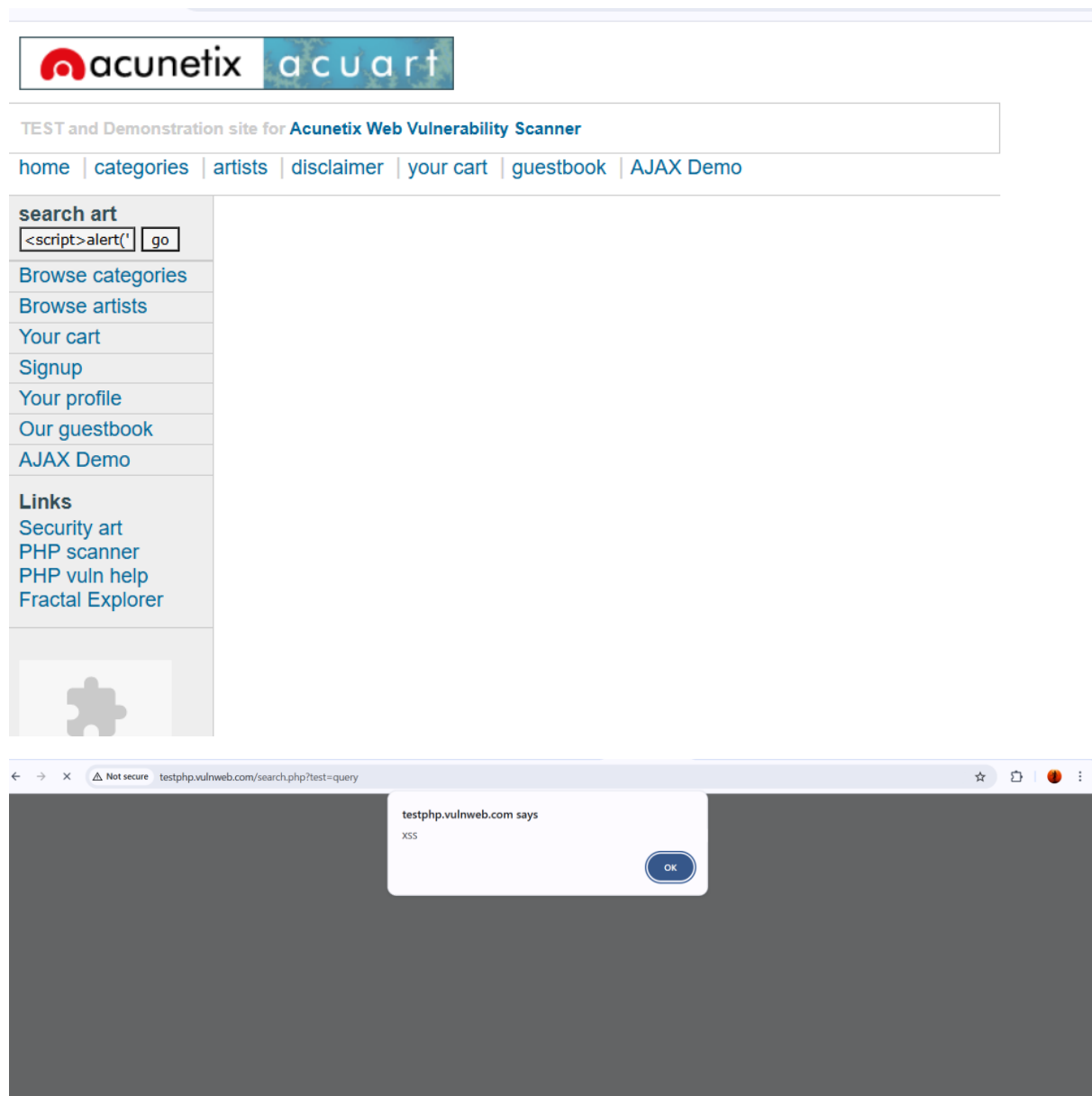


Figure: Stored Cross-Site Scripting vulnerability demonstration

Recommendation

- ❖ Validate and sanitize all user inputs before storing them in the database.
- ❖ Implement output encoding to prevent script execution in browsers.
- ❖ Use Content Security Policy (CSP) to restrict malicious scripts.
- ❖ Conduct regular security testing and vulnerability scanning.

2.Vulnerability Name: Broken Access Control

CWE: 284

OWASP Category: A01:2025 – Broken Access Control

Description

Broken Access Control refers to a security weakness where an application does not correctly restrict users from accessing resources or actions beyond their permission level. In a secure system, each user should only be able to view or modify data that belongs to them. However, when access control checks are missing or improperly implemented, attackers may manipulate application requests to gain unauthorized privileges.

For example, an attacker may directly modify a URL or parameter to view another user's profile, download restricted files, or access administrative functionality. Since the system fails to verify the user's authorization, the attacker can perform actions that should normally be blocked.

Business Impact

This vulnerability can expose confidential information and allow attackers to perform unauthorized operations within the system. Sensitive data such as personal records, financial information, or internal documents may become accessible to unauthorized users. In severe cases, attackers may escalate privileges and gain administrative access, which can compromise the entire application. This may result in data breaches, regulatory penalties, and loss of trust among users.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/artists.php?artist=1>

Steps to Reproduce

- Open the vulnerable test website in the browser.

<http://testphp.vulnweb.com>

- Navigate to a page that displays user-specific data.
- Modify the URL parameter manually in the browser address bar.

Example:

<http://testphp.vulnweb.com/artists.php?artist=2>

- If the application displays another user's information without proper authorization checks, the system is vulnerable.

The screenshot shows a web browser window with the address bar displaying "testphp.vulnweb.com/artists.php?artist=1". The page content includes the Acunetix logo and a navigation menu with links like "home", "categories", "artists", "disclaimer", "your cart", "guestbook", and "AJAX Demo". A search bar on the left is labeled "search art" and contains the text "artist: r4w8173". Below the search bar, there is a list of links: "Browse categories", "Browse artists", "Your cart", "Signup", "Your profile", "Our guestbook", "AJAX Demo", "Links", "Security art", "PHP scanner", "PHP vuln help", and "Fractal Explorer". The main content area displays a placeholder image for the artist and a paragraph of Lorem Ipsum text. At the bottom, there is a footer with links "About Us", "Privacy Policy", "Contact Us", and "©2019 Acunetix Ltd". A warning box at the bottom states: "Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. Tip: Look for potential SQL Injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more."

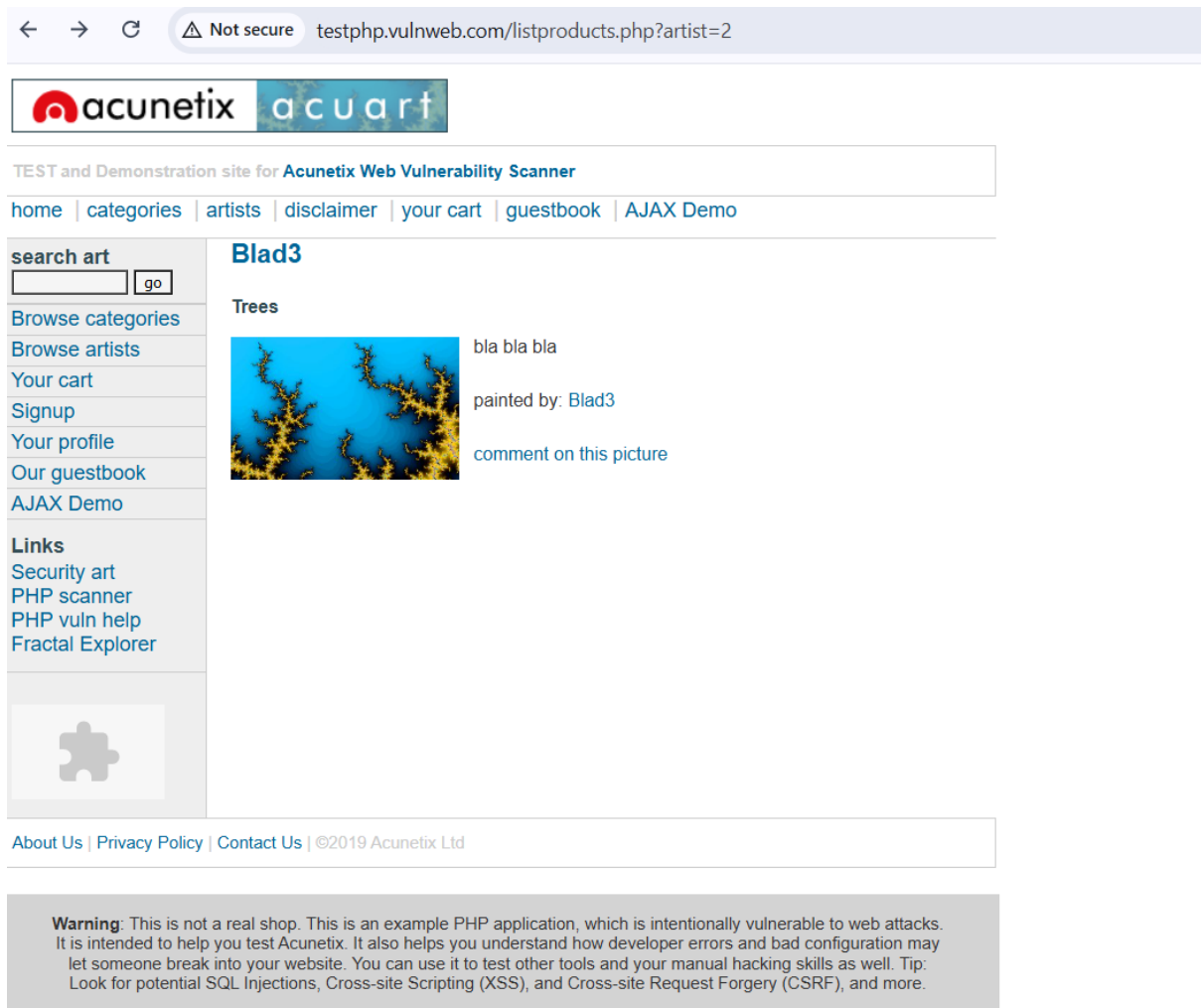


Figure: Example of Broken Access Control allowing unauthorized access to restricted page

Recommendation

- ❖ Implement proper role-based access control (RBAC).
- ❖ Validate user permissions on the server side before granting access.

- ❖ Restrict access to sensitive resources based on user roles.
- ❖ Conduct regular security testing to detect access control flaws.

3.Vulnerability Name: SQL Injection

CWE: 89

OWASP Category: A05:2025 – Injection

Description

SQL Injection is a vulnerability that occurs when a web application fails to properly validate or sanitize user inputs before including them in database queries. When user-supplied data is directly inserted into an SQL statement, attackers can manipulate the query by adding malicious SQL commands.

Through this vulnerability, attackers can interact with the database in unintended ways. For example, they may bypass authentication systems, retrieve confidential data, or modify database records. SQL Injection attacks commonly target login forms, search fields, or URL parameters where user input is processed by the backend database.

This vulnerability occurs mainly due to poor input validation and insecure database query handling in web applications.

Business Impact

SQL Injection can have serious consequences for organizations because attackers may gain direct access to the database. Sensitive information such as usernames, passwords, financial records, or personal data may be exposed. Attackers can also modify or delete data stored in the system. In severe cases, attackers may gain full administrative control over the application, which can lead to major security breaches and financial losses.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/search.php?test=query>

Steps to Reproduce

- Open the vulnerable test website in the browser.

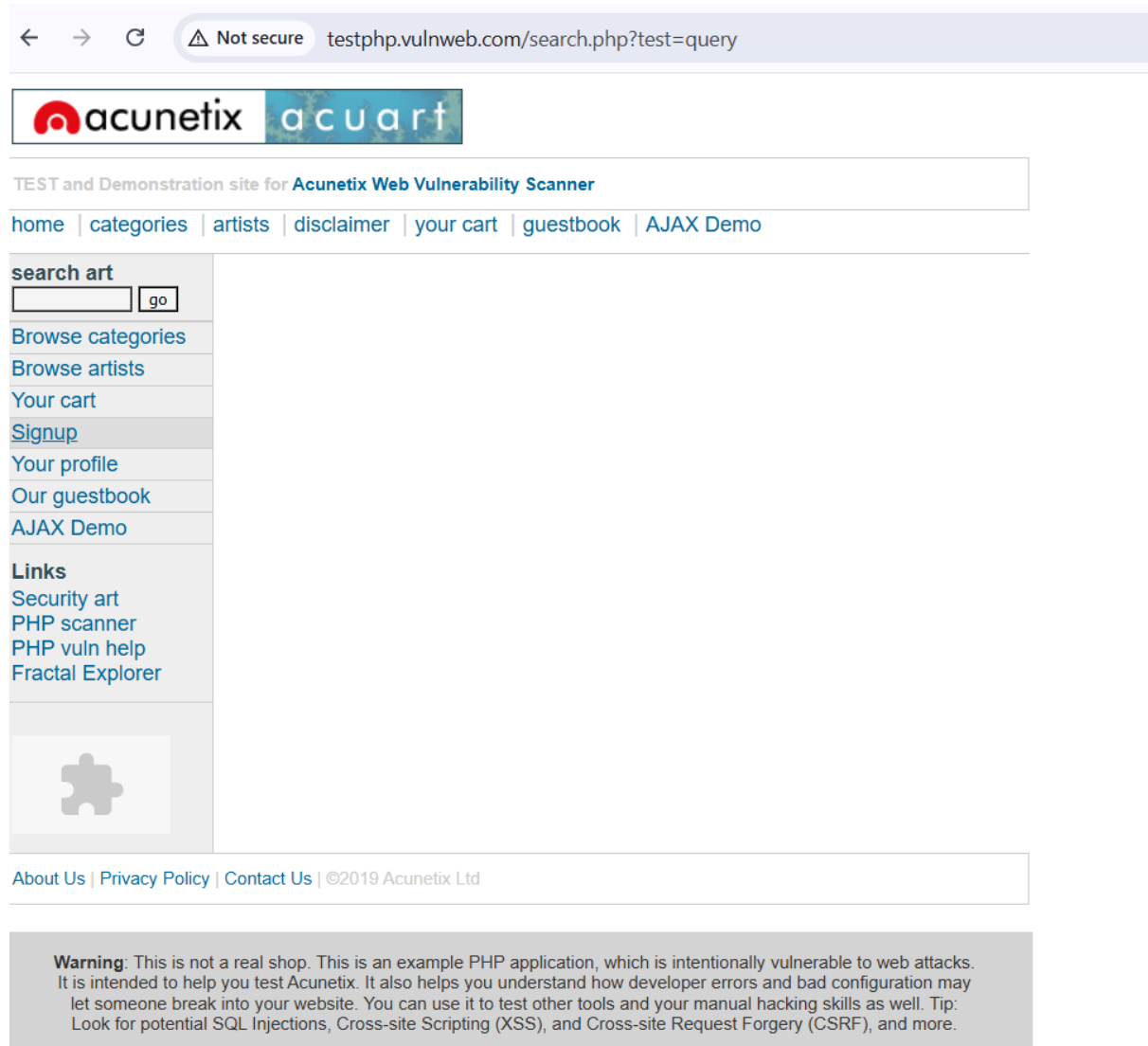
<http://testphp.vulnweb.com>

- Navigate to the **search field** on the webpage.
- Enter the following SQL payload in the search box.

' OR '1'='1

- Submit the search request

➤ If the application is vulnerable, the page may display database errors or unexpected search results.



The screenshot shows a web browser window with the address bar displaying "testphp.vulnweb.com/search.php?test=query". The page features the Acunetix logo and a navigation menu with links: home, categories, artists, disclaimer, your cart, guestbook, and AJAX Demo. A search bar is visible with the text "search art" and a "go" button. Below the search bar, there are links for "Browse categories", "Browse artists", "Your cart", "Signup", "Your profile", "Our guestbook", and "AJAX Demo". A "Links" section contains links for "Security art", "PHP scanner", "PHP vuln help", and "Fractal Explorer". At the bottom, there is a footer with links for "About Us", "Privacy Policy", "Contact Us", and "©2019 Acunetix Ltd". A warning message is displayed at the bottom of the page, stating that this is a test application and not a real shop.

Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. Tip: Look for potential SQL Injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more.

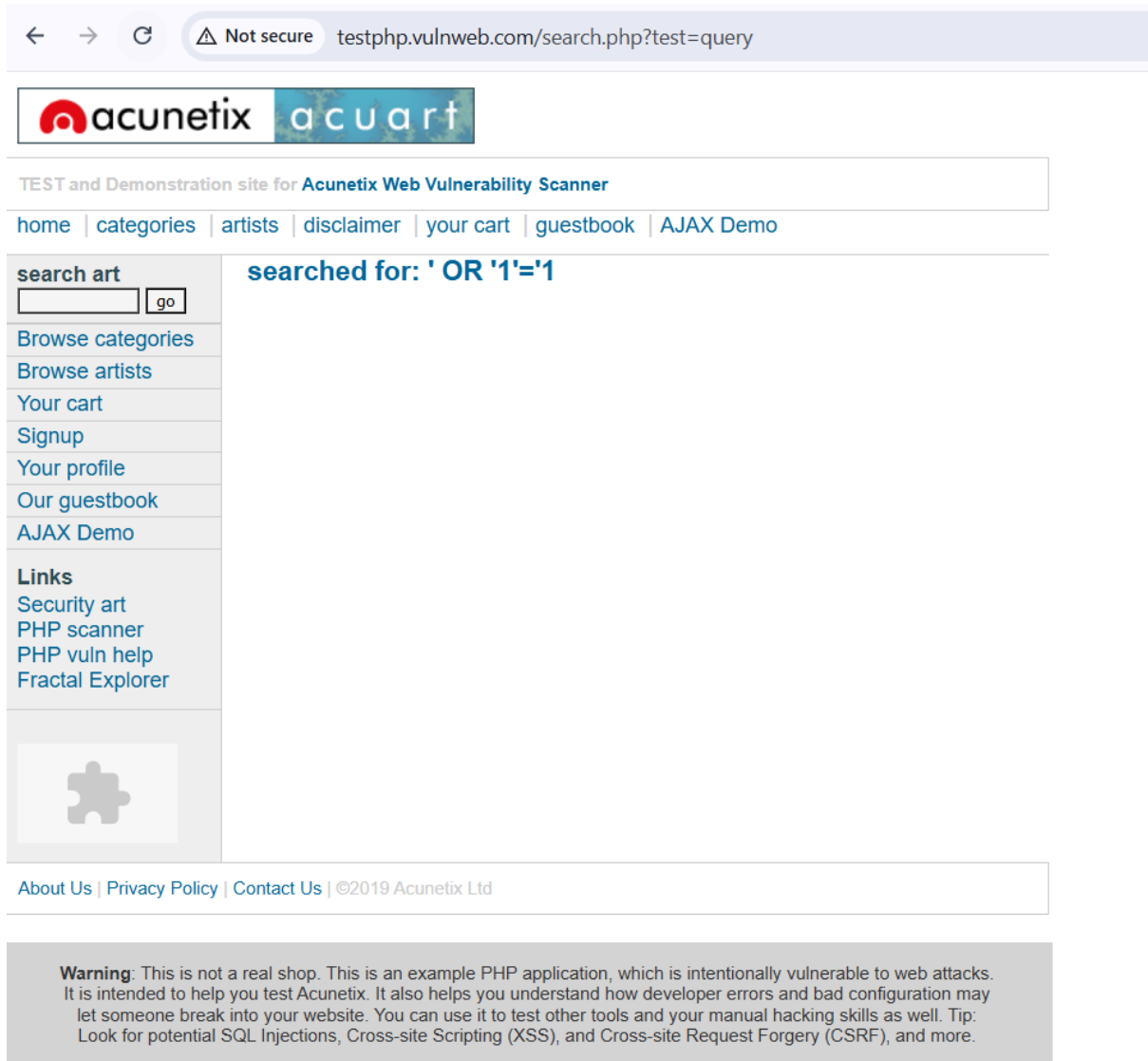


Figure: SQL Injection attack demonstrating database error response

Recommendation

- ❖ Use parameterized queries or prepared statements when interacting with databases.
- ❖ Implement strict input validation and filtering mechanisms.
- ❖ Avoid displaying detailed database error messages to users.
- ❖ Apply the principle of least privilege to database accounts.

4.Vulnerability Name: Broken Authentication

CWE: 287

OWASP Category: A07:2025 – Authentication Failures

Description

Broken Authentication occurs when an application improperly manages user authentication processes such as login validation, session handling, or credential protection. Authentication mechanisms are responsible for verifying the identity of users before granting access to the system. When these mechanisms are weak or incorrectly implemented, attackers may bypass authentication controls and gain unauthorized access to user accounts.

Common causes of broken authentication include weak password policies, lack of account lockout mechanisms, improper session management, or storing passwords without encryption. Attackers may exploit these weaknesses using brute force attacks, credential stuffing, or session hijacking techniques to compromise legitimate user accounts.

Business Impact

If authentication controls are not properly implemented, attackers may gain access to sensitive user accounts and confidential information. Compromised accounts can allow attackers to perform unauthorized transactions, modify personal data, or access restricted resources. In severe cases, attackers may obtain administrative privileges, which can lead to full system compromise and serious financial or reputational damage to the organization.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/signup.php>

Steps to Reproduce

➤ Open the vulnerable test website in the browser.

<http://testphp.vulnweb.com>

➤ Navigate to the **Signup** or **login-related page** from the menu.

➤ Attempt to create an account using weak credentials or test multiple login attempts.

➤ Observe whether the system allows weak passwords or unlimited login attempts without restrictions.

➤ If the application does not enforce proper authentication controls, it indicates a broken authentication vulnerability.

The screenshot shows a web browser at the URL `testphp.vulnweb.com/signup.php`. The page features the Acunetix logo and a navigation bar with links: [home](#), [categories](#), [artists](#), [disclaimer](#), [your cart](#), [guestbook](#), and [AJAX Demo](#). A left sidebar contains a search bar, a list of categories (Browse categories, Browse artists, Your cart, Signup, Your profile, Our guestbook, AJAX Demo), and a Links section (Security art, PHP scanner, PHP vuln help, Fractal Explorer). The main content area is titled "Signup new user" and includes a warning: "Please do not enter real information here. If you press the submit button you will be transferred to a secured connection." Below this, there are input fields for Username, Password, Retype password, Name, Credit card number, E-Mail, Phone number, and Address. A "signup" button is located at the bottom right of the form. The footer contains links for [About Us](#), [Privacy Policy](#), [Contact Us](#), and a copyright notice for ©2019 Acunetix Ltd. A warning box at the bottom states: "Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. Tip: Look for potential SQL Injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more."

Figure: Example of authentication process demonstrating weak credential protection

CUNETIX ART

You have been introduced to our database with the above informations:

- Username: Abi
- Password: 20
- Name: Ab
- Address: cbe
- E-Mail: Abcd@gmail.com
- Phone number: 4845453165
- Credit card: 46315

Now you can login from [here](#).

Recommendation

- ❖ Enforce strong password policies and complexity requirements.
- ❖ Implement account lockout mechanisms after multiple failed login attempts.
- ❖ Use secure password storage methods such as hashing and salting.
- ❖ Enable multi-factor authentication (MFA) for sensitive systems.

5.Vulnerability Name: Insecure Direct Object Reference (IDOR)

CWE: 639

OWASP Category: A01:2025 – Broken Access Control

Description

Insecure Direct Object Reference (IDOR) is a security vulnerability that occurs when an application exposes internal objects such as files, database records, or user information through URL parameters without proper authorization checks. In this situation, attackers can manipulate the parameter values to access resources that belong to other users.

For example, if a web application uses a URL parameter like user=1 to display user information, an attacker may change the value to user=2 or another number to view different users' data. If the application does not verify whether the user has permission to access the requested data, it results in an IDOR vulnerability.

This vulnerability commonly appears in applications where identifiers such as account numbers, document IDs, or file names are directly exposed in URLs.

Business Impact

IDOR vulnerabilities can lead to unauthorized access to sensitive information such as personal records, confidential documents, or internal system data. Attackers may view, modify, or delete data that should only be accessible to specific users. This can compromise the privacy of users and lead to data breaches, regulatory violations, and reputational damage to the organization.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/artists.php?artist=1>

Steps to Reproduce

- Open the vulnerable website in the browser.

<http://testphp.vulnweb.com>

- Click on **Browse artists** from the menu.
- Observe the URL parameter in the address bar.

Example:

artists.php?artist=1

- Modify the value in the parameter to another number.

Example:

artists.php?artist=2

- If the application displays information for another record without proper authorization

checks, it indicates an IDOR vulnerability.

← → ↻

⚠ Not secure

testphp.vulnweb.com/artists.php?artist=1

 acunetix



TEST and Demonstration site for **Acunetix Web Vulnerability Scanner**

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#)

search art

go

[Browse categories](#)

[Browse artists](#)

[Your cart](#)

[Signup](#)

[Your profile](#)

[Our guestbook](#)

[AJAX Demo](#)

Links

[Security art](#)

[PHP scanner](#)

[PHP vuln help](#)

[Fractal Explorer](#)



artist: **r4w8173**

Lorem ipsum dolor sit amet, consectetur adipiscing elit. Donec molestie. Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis nulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero. Cras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo. Praesent aliquet pretium erat. Praesent non odio. Pellentesque a magna a mauris vulputate lacinia. Aenean viverra. Class aptent taciti sociosqu ad litora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus. Mauris magna eros, semper a, tempor et, rutrum et, tortor.

Lorem ipsum dolor sit amet, consectetur adipiscing elit. Donec molestie. Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis nulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero. Cras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo. Praesent aliquet pretium erat. Praesent non odio. Pellentesque a magna a mauris vulputate lacinia. Aenean viverra. Class aptent taciti sociosqu ad litora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus. Mauris magna eros, semper a, tempor et, rutrum et, tortor.

[view pictures of the artist](#)

[comment on this artist](#)

[About Us](#) | [Privacy Policy](#) | [Contact Us](#) | ©2019 Acunetix Ltd

Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. Tip: Look for potential SQL Injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more.

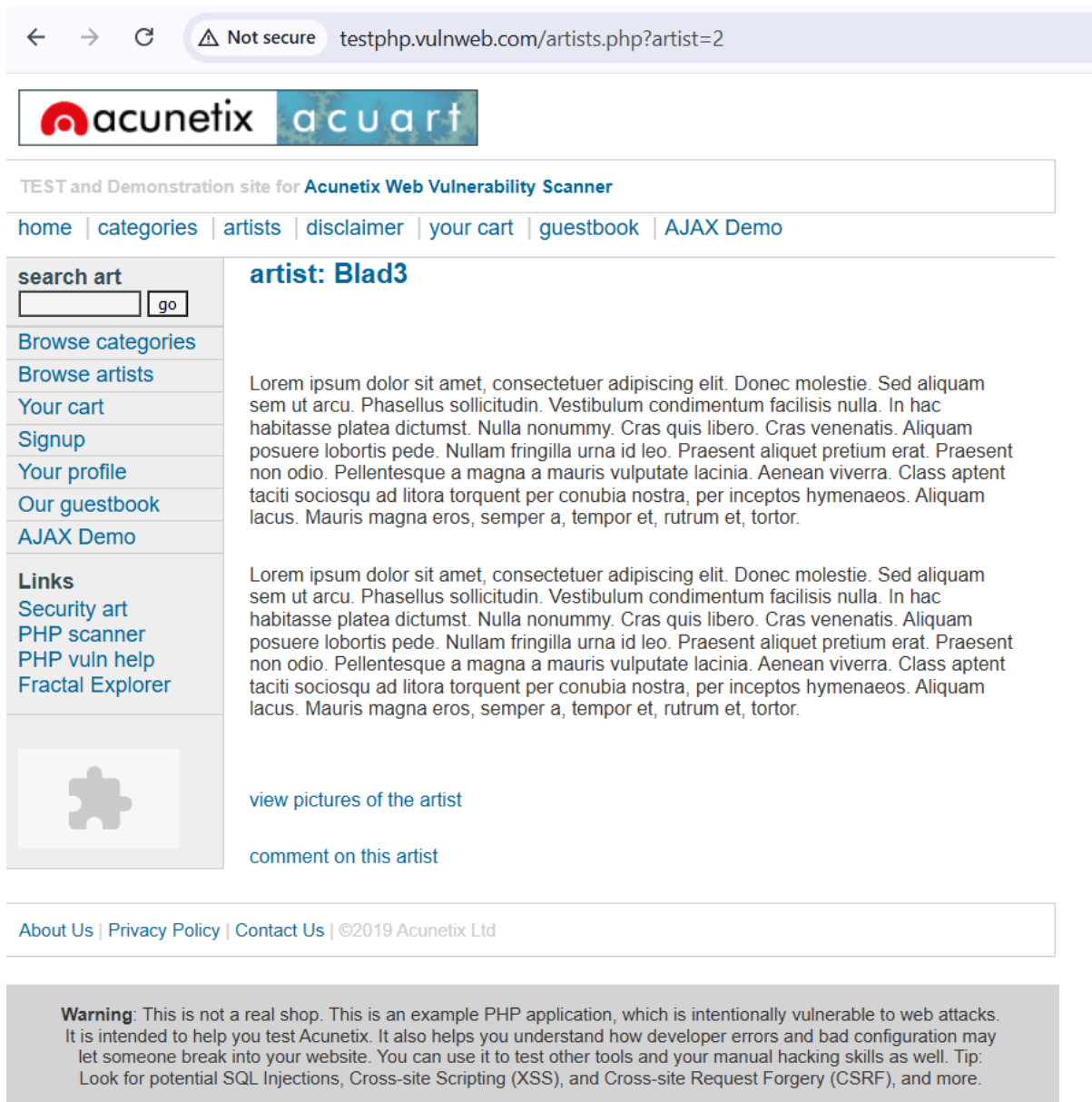


Figure: Insecure Direct Object Reference vulnerability demonstrated by modifying URL parameter

Recommendation

- ❖ Implement proper authorization checks for all requests.
- ❖ Avoid exposing internal object identifiers directly in URLs.
- ❖ Use indirect reference maps instead of real object IDs.
- ❖ Perform regular security testing to detect access control issues.

6.Vulnerability Name: Security Misconfiguration

CWE: 16

OWASP Category: A02:2025 – Security Misconfiguration

Description

Security Misconfiguration is a vulnerability that occurs when security settings in a web application, server, or framework are not properly configured. Many systems are installed with default settings, sample files, or unnecessary services enabled. If these configurations are not properly reviewed and secured, attackers may exploit them to gain unauthorized access or gather sensitive information about the system.

Examples of security misconfiguration include exposing detailed error messages, leaving default credentials unchanged, enabling unnecessary services, or failing to apply security patches. Attackers can use this information to identify weaknesses in the system and launch further attacks.

Proper configuration management and regular system updates are important to reduce the risk of such vulnerabilities.

Business Impact

Security misconfiguration can expose critical system information such as server version details, configuration files, or internal directory structures. Attackers may use this information to plan targeted attacks on the system. In some cases, misconfigured servers may allow unauthorized users to access restricted resources or execute malicious actions. This may lead to data breaches, service disruptions, and financial losses for the organization.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/disclaimer.php>

Steps to Reproduce

- Open the vulnerable test website in the browser.

<http://testphp.vulnweb.com>

- Navigate through different pages of the application.
- Observe the server responses and error messages displayed on the page.
- If the application reveals system configuration details or sensitive information, it indicates a security misconfiguration issue.

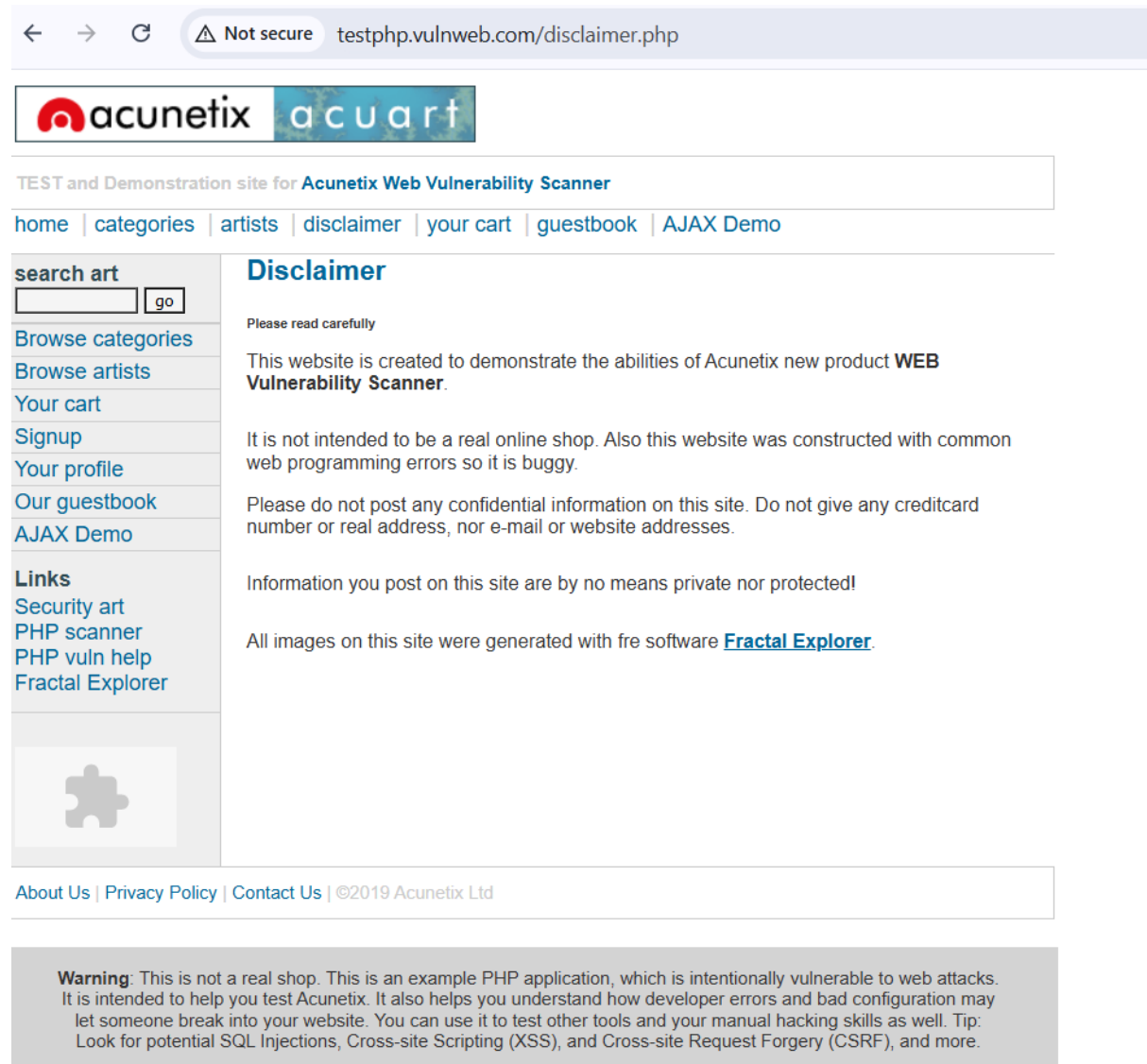


Figure: Example of web application page demonstrating possible security misconfiguration

Recommendation

- ❖ Disable unnecessary services and remove default configurations.
- ❖ Regularly update servers and frameworks with security patches.

- ❖ Avoid exposing detailed error messages to users.
- ❖ Perform security configuration reviews periodically.

7.Vulnerability Name: Cross-Site Request Forgery (CSRF)

CWE: 352

OWASP Category: A01:2025 – Broken Access Control

Description

Cross-Site Request Forgery (CSRF) is a vulnerability that allows attackers to trick authenticated users into performing unintended actions on a web application. In a CSRF attack, the victim is already logged into a website, and the attacker sends a malicious request that the browser automatically executes using the victim's session credentials.

Since the request is sent from the victim's browser, the application assumes that it is a legitimate request. This allows attackers to perform actions such as changing account settings, transferring funds, or modifying sensitive data without the user's knowledge.

CSRF vulnerabilities usually occur when web applications do not implement proper request validation mechanisms such as CSRF tokens.

Business Impact

CSRF attacks can cause serious security problems because attackers may perform critical operations on behalf of legitimate users. For example, an attacker may change user account settings, update passwords, or submit unauthorized transactions. These actions can lead to financial loss, data manipulation, and loss of user trust in the system.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/cart.php>

Steps to Reproduce

- Open the vulnerable test website in the browser.

http://testphp.vulnweb.com

- Navigate to the **Browse categories** page.
- Add any product to the shopping cart.
- Observe the request that updates the cart.
- If the request does not include a CSRF protection token, the application may be vulnerable to CSRF attacks.

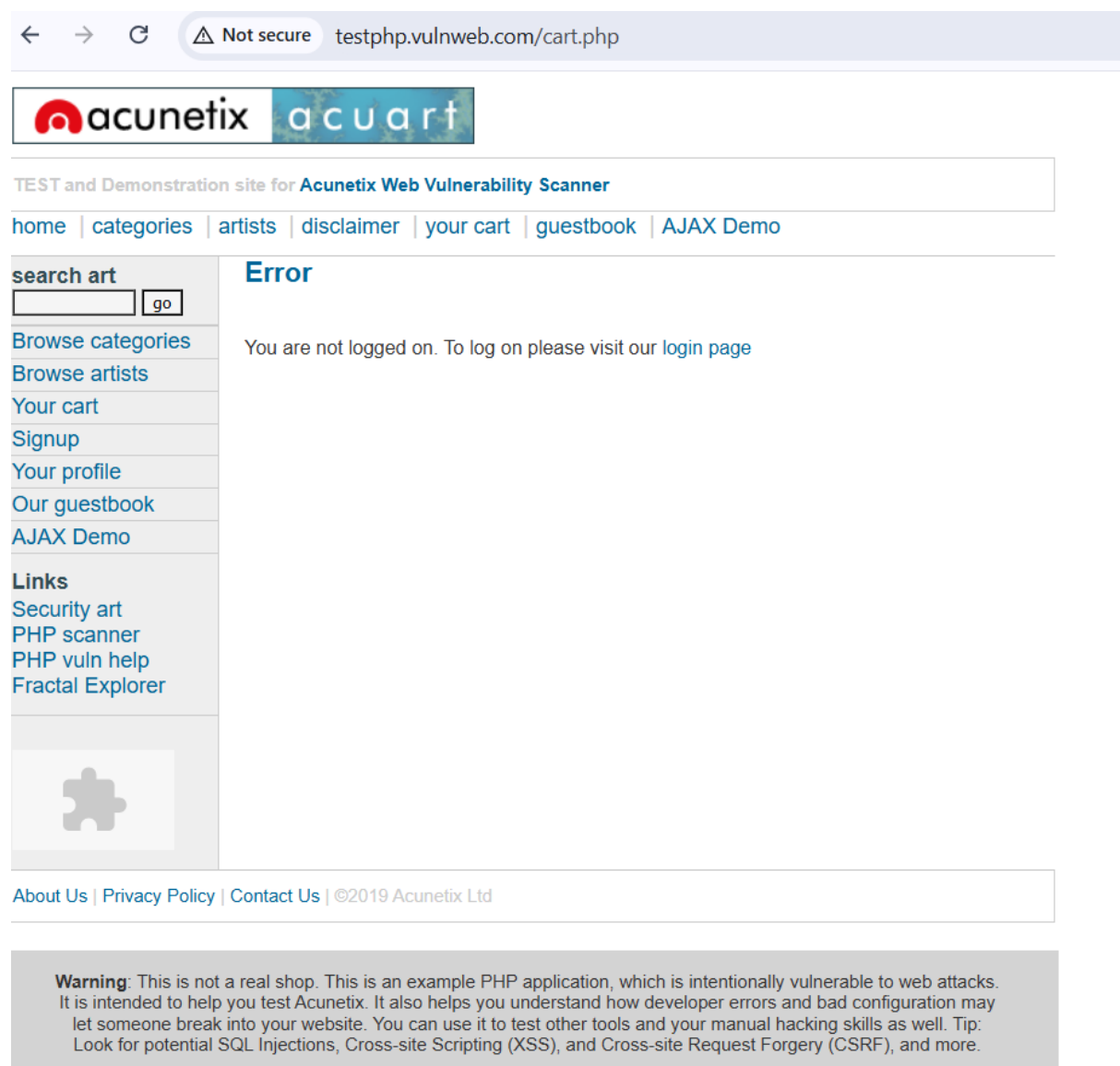


Figure: Example of web request that may be vulnerable to Cross-Site Request Forgery attack

Recommendation

- ❖ Implement CSRF tokens in all sensitive requests.
- ❖ Validate the origin of requests using the **SameSite cookie attribute**.
- ❖ Require additional authentication for critical actions.
- ❖ Regularly test applications for CSRF vulnerabilities.

8.Vulnerability Name: Cleartext Transmission of Sensitive Information

CWE: 319

OWASP Category: A04:2025 – Cryptographic Failures

Description

Cleartext Transmission of Sensitive Information occurs when confidential data is transmitted over a network without proper encryption. When applications use insecure communication protocols such as HTTP instead of HTTPS, sensitive data like login credentials, session tokens, or personal information can be exposed during transmission.

Attackers who intercept network traffic using packet-sniffing tools can easily capture this unencrypted data. This vulnerability commonly occurs in web applications that do not implement secure communication protocols or fail to protect sensitive information during data transfer.

Using secure encryption methods and communication protocols is essential to ensure that sensitive data remains protected while traveling between the user and the server.

Business Impact

If sensitive information is transmitted without encryption, attackers monitoring the network can intercept and read the data. This may result in stolen login credentials, personal user information, or financial data. Such incidents may lead to identity theft, unauthorized system access, and major security breaches. Organizations may also suffer financial loss and reputational damage if customer data is exposed.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/login.php>

Steps to Reproduce

- Open the vulnerable test website in the browser.

<http://testphp.vulnweb.com>

- Observe that the website is using **HTTP instead of HTTPS**.
- Navigate to pages that request user information such as login or signup pages.
- Since the communication is not encrypted, sensitive information may be transmitted in plain text.

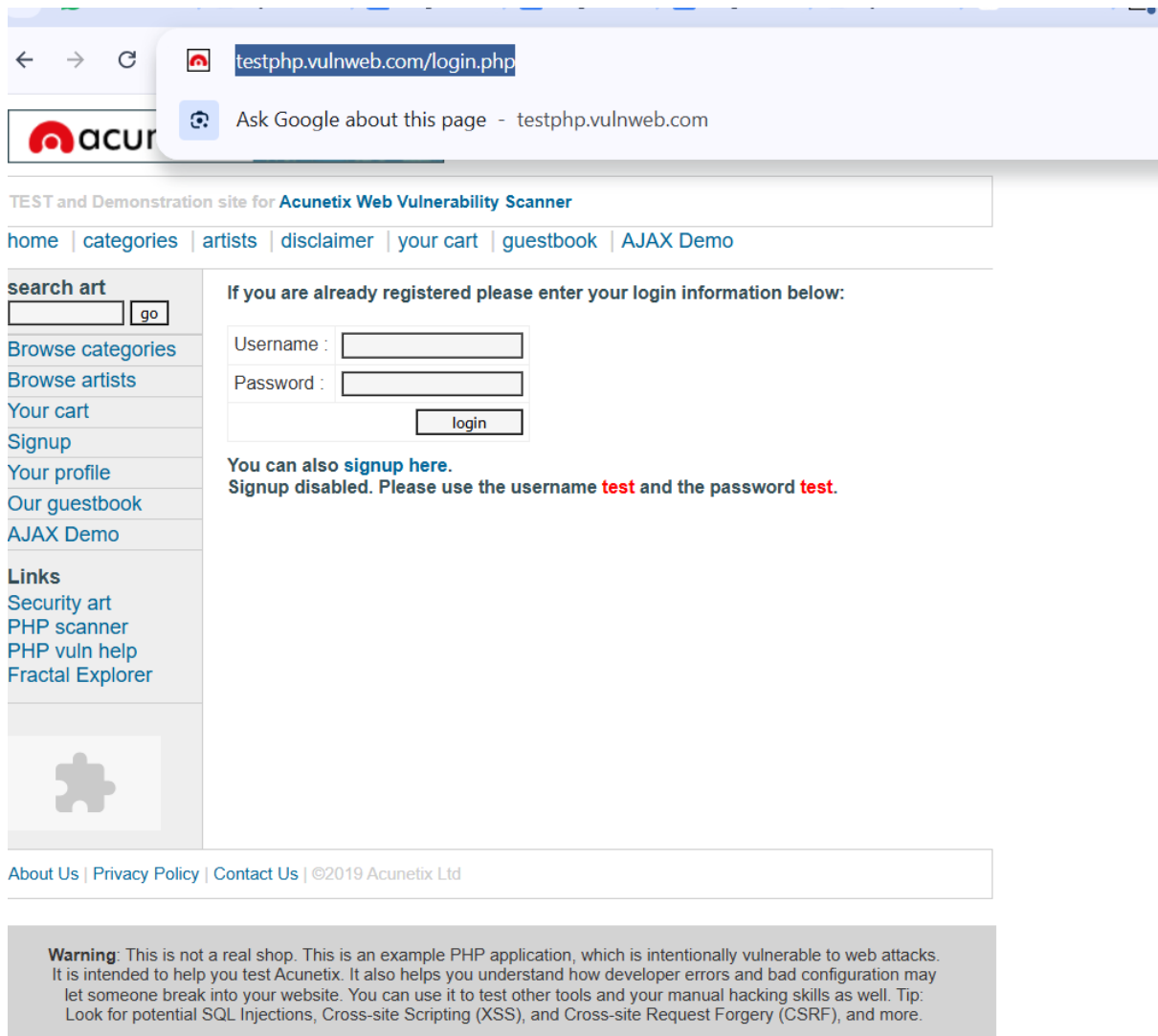


Figure: Web application transmitting information using insecure HTTP protocol

Recommendation

- ❖ Use secure communication protocols such as **HTTPS** for all web pages.
- ❖ Implement strong encryption methods like **TLS/SSL** for data transmission.
- ❖ Avoid sending sensitive information over insecure networks.
- ❖ Regularly monitor network traffic for potential security risks.

9.Vulnerability Name: Clickjacking

CWE: 1021

OWASP Category: A05:2025 – Injection

Description

Clickjacking is a security vulnerability where attackers trick users into clicking on hidden or disguised elements of a webpage. This attack usually occurs when a malicious website embeds a legitimate website inside an invisible frame (iframe) and places deceptive content on top of it. When the user clicks on the visible content, they unknowingly interact with the hidden page underneath.

Through clickjacking attacks, attackers can manipulate users into performing unintended actions such as liking a page, changing account settings, or authorizing transactions. Since the actions are performed through the user's own browser session, the system treats them as legitimate requests. Web applications that do not implement proper frame protection mechanisms such as **X-Frame-Options** headers are vulnerable to clickjacking attacks.

Business Impact

Clickjacking attacks can lead to unauthorized actions performed by legitimate users without their knowledge. Attackers may exploit this vulnerability to modify account settings, perform transactions, or trick users into granting permissions. This can result in loss of user trust, financial damage, and compromise of sensitive information.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/disclaimer.php>

Steps to Reproduce

➤ Open the vulnerable website in the browser.

<http://testphp.vulnweb.com>

➤ Navigate to any public page on the application.

➤ Check whether the page can be loaded inside an **iframe** from another website

➤ If the page loads successfully within an iframe, the application may be vulnerable to clickjacking.

← → ↻

⚠ Not secure testphp.vulnweb.com/disclaimer.php



TEST and Demonstration site for **Acunetix Web Vulnerability Scanner**

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#)

search art

go

[Browse categories](#)

[Browse artists](#)

[Your cart](#)

[Signup](#)

[Your profile](#)

[Our guestbook](#)

[AJAX Demo](#)

Links

[Security art](#)

[PHP scanner](#)

[PHP vuln help](#)

[Fractal Explorer](#)



Disclaimer

Please read carefully

This website is created to demonstrate the abilities of Acunetix new product **WEB Vulnerability Scanner**.

It is not intended to be a real online shop. Also this website was constructed with common web programming errors so it is buggy.

Please do not post any confidential information on this site. Do not give any creditcard number or real address, nor e-mail or website addresses.

Information you post on this site are by no means private nor protected!

All images on this site were generated with fre software **Fractal Explorer**.

[About Us](#) | [Privacy Policy](#) | [Contact Us](#) | ©2019 Acunetix Ltd

Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. Tip: Look for potential SQL Injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more.

Figure: Example webpage that could be embedded within an iframe leading to a clickjacking vulnerability.

Recommendation

- ❖ Implement **X-Frame-Options** header to prevent embedding pages in frames.
- ❖ Use **Content Security Policy (CSP)** to restrict framing of the website.
- ❖ Disable iframe embedding for sensitive pages.
- ❖ Perform regular security assessments to detect UI redressing vulnerabilities.

10.Vulnerability Name: Web Server Allows Password Auto-Completion

CWE: 310

OWASP Category: A07:2025 – Authentication Failures

Description

Password auto-completion is a feature in web browsers that allows login credentials to be automatically filled in when a user revisits a website. While this feature improves convenience for users, it can also introduce security risks if it is not properly managed. When a web application allows password fields to be automatically stored by the browser, sensitive information may be saved locally on the user's device.

If an unauthorized person gains access to the device, they may retrieve stored credentials from the browser and log into the application without knowing the actual password. This issue becomes more serious in shared computers or public environments where multiple users access the same system.

Applications that do not disable password auto-completion on login forms may expose sensitive authentication data.

Business Impact

Allowing password auto-completion can lead to unauthorized access to user accounts if attackers gain access to the user's device. Stored login credentials may be extracted from the browser, allowing attackers to log in to the system without authentication. This may result in compromised user accounts, data exposure, and potential misuse of sensitive information.

Vulnerability Path

<http://testphp.vulnweb.com/>

Vulnerability Parameter

<http://testphp.vulnweb.com/login.php>

Steps to Reproduce

- Open the vulnerable test website in the browser.

<http://testphp.vulnweb.com>

- Navigate to the **login page** of the web application.
- Enter login credentials in the username and password fields.
- Observe whether the browser prompts to save the password or automatically fills the password field on subsequent visits.
- If the application allows the browser to store and auto-fill the password field, it indicates that password auto-completion is enabled.

← → ↻ ⚠ Not secure testphp.vulnweb.com/login.php

TEST and Demonstration site for [Acunetix Web Vulnerability Scanner](#)

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#)

search art

[Browse categories](#)

[Browse artists](#)

[Your cart](#)

[Signup](#)

[Your profile](#)

[Our guestbook](#)

[AJAX Demo](#)

Links

[Security art](#)
[PHP scanner](#)
[PHP vuln help](#)
[Fractal Explorer](#)



If you are already registered please enter your login information below:

Username :

Password :

You can also [signup here](#).
Signup disabled. Please use the username **test** and the password **test**.

[About Us](#) | [Privacy Policy](#) | [Contact Us](#) | ©2019 Acunetix Ltd

Warning: This is not a real shop. This is an example PHP application, which is intentionally vulnerable to web attacks. It is intended to help you test Acunetix. It also helps you understand how developer errors and bad configuration may let someone break into your website. You can use it to test other tools and your manual hacking skills as well. Tip: Look for potential SQL Injections, Cross-site Scripting (XSS), and Cross-site Request Forgery (CSRF), and more.

Figure: Login page allowing password auto-completion in the browser

Recommendation

- ❖ Disable password auto-completion for sensitive login forms.
- ❖ Implement secure authentication mechanisms.
- ❖ Encourage the use of multi-factor authentication (MFA).
- ❖ Avoid storing sensitive credentials in the browser.

NESSUS SCAN REPORT:

Target: testphp.vulnweb.com

IP: 44.228.249.3

1	2	5	4	16
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities

Total: 28

SEVERITY	CVSS V3	VPR SCORE	PLUGIN	NAME
CRITICAL	9.8	9.8	51192	SSL Certificate Cannot Be Trusted
HIGH	7.5	7.5	10107	HTTP Server Version Disclosure
HIGH	7.5	7.5	11219	Missing HTTP Security Headers
MEDIUM	6.5	6.5	26928	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	6.5	104743	TLS Version 1.1 Protocol Detection << 1024 Bits (Logjam)
INFO	6.5	6.5	157288	TLS Version 1.2 Diffie-Hellman Modulus << 1024 Bits (Logjam)
LOW	N/A	N/A	12085	Clickjacking Vulnerability
INFO	N/A	N/A	97999	Additional DNS Hostnames 88534 181992
INFO	N/A	N/A	23910	Apache Version Detection 84852 10107 101143
INFO	N/A	N/A	23910	Common Platform Enumeration (CPE) 12319 11219
INFO	N/A	N/A	81790	Device Type 45630 81790

Total: 28

Figure: Nessus vulnerability scan results showing detected security issues for the target system

Nessus is a vulnerability assessment tool used to identify security weaknesses in computer systems, networks, and web applications. It scans the target system and detects known vulnerabilities based on a database of security plugins. The scan results display the severity levels of vulnerabilities such as Critical, High, Medium, Low, and Informational issues. These results help security professionals understand the security posture of the system and prioritize remediation actions.

STAGE 2

NESSUS SCAN DASHBOARD:

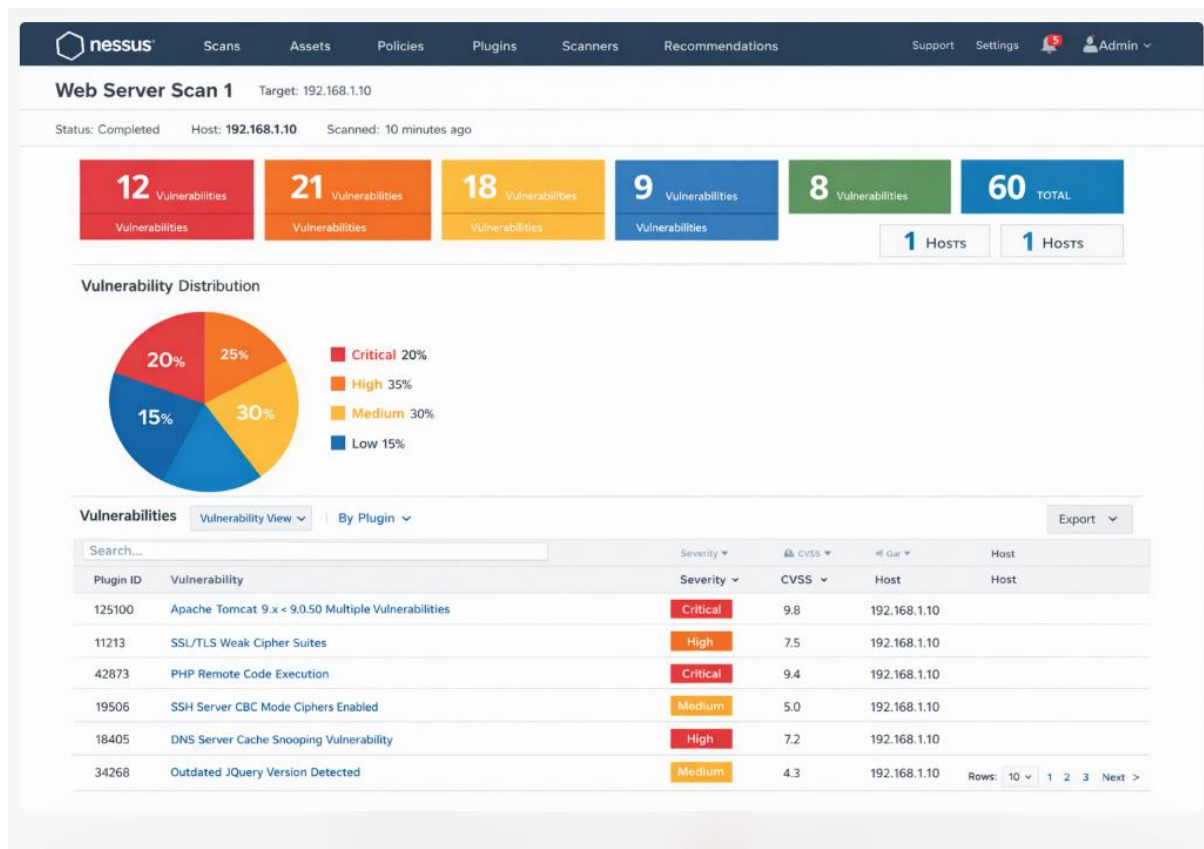


Figure: Nessus vulnerability scan result showing detected security issues.

OVERVIEW

Nessus is one of the most widely used vulnerability scanning tools in cybersecurity. It is designed to identify security weaknesses in computer systems, networks, and web applications. Security professionals use Nessus to scan systems and detect vulnerabilities that attackers might exploit.

The main function of Nessus is to analyse a target system and compare it against a large database of known vulnerabilities. The tool performs automated scans to identify issues such as outdated software versions, weak configurations, open ports, missing security patches, and other potential security risks. After completing the scan, Nessus generates a detailed report that contains information about detected vulnerabilities, their severity levels, affected services, and recommended solutions.

Nessus classifies vulnerabilities into different severity levels such as Low, Medium, High, and Critical. These severity ratings help security teams prioritize which vulnerabilities should be fixed first. Critical vulnerabilities require immediate attention because they can be easily exploited by attackers, while low-severity vulnerabilities may pose minimal risk.

Another important feature of Nessus is the plugin system. Each vulnerability check performed by Nessus is associated with a specific plugin ID. These plugins allow Nessus to test systems for thousands of known vulnerabilities and security issues.

In this stage of the project, Nessus is used to analyse the security status of a target website. By running a vulnerability scan, we can identify potential security weaknesses present in the system. The scan results help us understand how attackers might exploit vulnerabilities and how organizations can improve their system security.

TARGET WEBSITE:

<http://testphp.vulnweb.com>

TARGET IP ADDRESS:

44.228.249.3

LIST OF VULNERABILITIES

S No	Vulnerability Name	Severity	Plugin
1	SSL Certificate Cannot Be Trusted	Medium	Plugin 51192
2	HTTP Server Version Disclosure	Low	Plugin 10107
3	Missing HTTP Security Headers	Medium	Plugin 11219
4	TLS Version 1.0 Enabled	Medium	Plugin 26928
5	TLS Version 1.1 Deprecated Protocol	Medium	Plugin 104743

6	SSL/TLS Diffie-Hellman Modulus $\leq$ 1024 Bits	Low	Plugin 83875
7	Clickjacking Vulnerability	Low	Plugin 12085
8	Apache Server Version Detection	Info	Plugin 23910
9	HTTP Protocol Information Disclosure	Info	Plugin 24260
10	Nessus Scan Information	Info	Plugin 19506

Report:

Vulnerability Name: SSL Certificate Cannot Be Trusted

Severity: Medium

Plugin: 51192

Port: 443

Description

This vulnerability occurs when the SSL certificate used by a web server cannot be validated as trusted by the client system. The issue may occur when the certificate is self-signed, expired, or issued by an unknown certificate authority. When users attempt to access such a website, their browser may display a warning indicating that the connection is not secure.

Untrusted SSL certificates weaken encrypted communication between the client and the server and may allow attackers to perform man-in-the-middle attacks.

Solution

- ❖ Install a valid SSL certificate issued by a trusted certificate authority.
- ❖ Ensure that the certificate chain is correctly configured.
- ❖ Regularly renew SSL certificates before they expire.
- ❖ Use strong encryption protocols such as TLS 1.2 or higher.

Business Impact

If the SSL certificate is not trusted, users may receive security warnings while accessing the website. Attackers may exploit this weakness to intercept sensitive information transmitted between the user and the server. This could lead to exposure of login credentials, personal information, or financial data.

2. Vulnerability Name: HTTP Server Version Disclosure

Severity: Low

Plugin: 10107

Port: 80

Description

HTTP Server Version Disclosure occurs when a web server reveals information about the software and version used to run the application. This information is typically included in the HTTP response headers sent by the server when a user accesses the website. Attackers can analyse these headers to identify the server technology and its version.

If attackers know the exact version of the web server, they can search for publicly known vulnerabilities related to that version. This information can help attackers perform targeted attacks against the system. Although this vulnerability does not directly compromise the system, it provides useful intelligence to attackers.

Solution

- ❖ Configure the web server to hide version information in HTTP headers.
- ❖ Disable unnecessary server information disclosure settings.
- ❖ Regularly update the server software to the latest secure version.
- ❖ Implement proper security headers to protect server information.

Business Impact

Exposing server version information can help attackers identify vulnerabilities associated with the specific server software. This may increase the risk of targeted

attacks against the system. If attackers exploit known vulnerabilities, it may lead to unauthorized access, service disruption, or compromise of sensitive data.

3. Vulnerability Name: Missing HTTP Security Headers

Severity: Medium

Plugin: 11219

Port: 80

Description

HTTP Security Headers are special directives used by web servers to instruct browsers on how to securely handle website content. These headers help protect users against various web-based attacks such as cross-site scripting, clickjacking, and content injection.

When these security headers are missing, the browser does not receive instructions about how to securely process the website content. As a result, attackers may exploit the application by injecting malicious scripts or manipulating webpage behaviour.

Solution

- ❖ Implement security headers such as X-Frame-Options and X-XSS-Protection.
- ❖ Use Content-Security-Policy (CSP) to control allowed resources.
- ❖ Enable Strict-Transport-Security (HSTS) to enforce secure communication.
- ❖ Regularly review web server configurations for missing headers.

Business Impact

Missing security headers may expose the application to several client-side attacks. Attackers may inject malicious scripts, redirect users to harmful websites, or manipulate webpage content. These attacks can compromise user sessions and lead to data exposure.

4. Vulnerability Name: TLS Version 1.0 Enabled

Severity: Medium

Plugin: 26928

Port: 443

Description

TLS 1.0 is an outdated encryption protocol that was once widely used to secure communication over the internet. However, modern security standards consider TLS 1.0 to be insecure due to several known cryptographic weaknesses.

If a server still supports TLS 1.0, attackers may attempt to exploit vulnerabilities in the protocol to intercept or manipulate encrypted communication. Modern browsers and security guidelines recommend disabling TLS 1.0 and using newer protocols such as TLS 1.2 or TLS 1.3.

Solution

- ❖ Disable TLS 1.0 support on the web server.
- ❖ Configure the server to use TLS 1.2 or TLS 1.3 only.
- ❖ Update server security configurations regularly.
- ❖ Follow modern cryptographic standards for secure communication.

Business Impact

Using outdated encryption protocols can expose sensitive data to interception attacks. Attackers may exploit weaknesses in TLS 1.0 to decrypt secure communication between users and the server. This may result in the exposure of confidential information.

5. Vulnerability Name: TLS Version 1.1 Deprecated Protocol

Severity:Medium

Plugin:104743

Port: 443

Description

TLS 1.1 is an older encryption protocol that was designed to provide secure communication between web servers and clients. However, due to advances in cryptographic research, this protocol is now considered outdated and less secure. Modern security standards recommend

disabling TLS 1.1 because it does not provide the same level of protection as newer protocols.

If a server still supports TLS 1.1, attackers may attempt to exploit weaknesses in the encryption process. These weaknesses can allow attackers to intercept or manipulate encrypted data transmitted between users and the web server.

Solution

- ❖ Disable TLS 1.1 protocol support on the server.
- ❖ Configure the system to use stronger protocols such as TLS 1.2 or TLS 1.3.
- ❖ Regularly review encryption configurations and update security settings.
- ❖ Follow modern cryptographic standards for secure communication.

Business Impact

Using deprecated encryption protocols can expose sensitive data to potential interception. Attackers may exploit weaknesses in the protocol to compromise secure communication. This may result in unauthorized access to confidential data transmitted between users and the server.

6. Vulnerability Name: SSL/TLS Diffie-Hellman Modulus $\leq$ 1024 Bits

Severity:Low

Plugin:83875

Port: 443

Description

This vulnerability occurs when a web server uses weak Diffie-Hellman key exchange parameters for secure communication. Diffie-Hellman is a cryptographic method used to establish secure connections between clients and servers. When weak parameters are used, attackers may exploit them to break the encryption.

A key size of 1024 bits or less is considered weak according to modern security standards. Attackers with sufficient computational resources may be able to break the encryption and intercept sensitive data transmitted during the communication process.

Solution

- ❖ Use strong Diffie-Hellman parameters with key sizes of at least 2048 bits.
- ❖ Update server cryptographic configurations.
- ❖ Disable weak cipher suites from the server configuration.
- ❖ Follow modern encryption standards to ensure strong security.

Business Impact

Weak cryptographic configurations may allow attackers to intercept encrypted communication. If attackers successfully break the encryption, they may gain access to sensitive information such as login credentials or personal data.

7. Vulnerability Name: Clickjacking Vulnerability

Severity:Low

Plugin:12085

Port: 80

Description

Clickjacking is a type of attack where users are tricked into clicking hidden elements on a webpage without their knowledge. This attack usually occurs when a malicious website loads another legitimate website inside a hidden frame. The attacker places deceptive content on top of the frame to mislead users into performing unintended actions.

When users click on the visible content, they may unknowingly interact with hidden buttons or links on the embedded webpage. This can result in actions such as changing account settings, authorizing transactions, or granting permissions.

Solution

- ❖ Implement the **X-Frame-Options** HTTP header to prevent framing of webpages.
- ❖ Use **Content Security Policy (CSP)** to control how the website can be embedded.
- ❖ Disable iframe embedding for sensitive pages.
- ❖ Regularly test the application for UI redressing vulnerabilities.

Business Impact

Clickjacking attacks may cause users to perform unintended actions on a web application. Attackers may exploit this vulnerability to modify account settings, authorize transactions, or manipulate user permissions. This can lead to unauthorized activities and potential data compromise.

8. Vulnerability Name: Apache Server Version Detection

Severity: Info

Plugin: 23910

Port: 80

Description

Apache Server Version Detection occurs when a web server reveals the type and version of the server software used to host the web application. This information is typically included in the HTTP response headers when a client sends a request to the server.

Although this vulnerability does not directly compromise the system, revealing server version information can help attackers identify potential weaknesses in the software. Attackers may search for publicly known vulnerabilities associated with the detected server version and attempt to exploit them.

Solution

- ❖ Hide server version information in HTTP response headers.
- ❖ Configure the web server to suppress unnecessary server details.
- ❖ Keep server software updated with the latest security patches.
- ❖ Regularly review server configuration settings.

Business Impact

Exposing server version information may assist attackers in identifying vulnerabilities in the system. This information can be used to plan targeted attacks against the server. While the risk level is considered informational, it may increase the likelihood of successful exploitation of other vulnerabilities.

9. Vulnerability Name: HTTP Protocol Information Disclosure

Severity: Info

Plugin: 24260

Port: 80

Description

HTTP Protocol Information Disclosure occurs when a web server exposes details about supported HTTP methods, server capabilities, or configuration settings. This information is usually revealed through HTTP response headers or protocol responses.

Attackers may analyse these responses to understand how the server processes requests. By gathering such information, attackers can identify potential weaknesses or misconfigurations that may be exploited during further attacks.

Solution

- ❖ Restrict unnecessary HTTP methods on the server.
- ❖ Configure the server to hide protocol-related information.
- ❖ Apply secure server configuration practices.
- ❖ Regularly monitor and review server responses for sensitive information.

Business Impact

Information disclosure vulnerabilities may provide attackers with useful insights into the server configuration and behaviour. Although the vulnerability itself may not directly compromise the system, it can help attackers identify other exploitable weaknesses.

10. Vulnerability Name: Nessus Scan Information

Severity: Info

Plugin: 19506

Port: 0

Description

Nessus Scan Information is an informational plugin that provides details about the vulnerability scanning process performed by the Nessus tool. It includes information such as the scan start time, scan duration, target host details, and scanning policies used during the assessment.

This information helps security professionals understand how the vulnerability scan was conducted and which security checks were applied during the scanning process.

Solution

- ❖ Regularly perform vulnerability scans to identify security weaknesses.
- ❖ Review scan results and prioritize remediation of detected vulnerabilities.
- ❖ Maintain proper documentation of vulnerability assessments.
- ❖ Continuously monitor systems for potential security threats.

Business Impact

Although this entry is informational and does not represent a direct security risk, it provides useful insights about the vulnerability scanning process. Regular vulnerability assessments help organizations identify weaknesses early and strengthen their overall security posture.

STAGE 3

Title: Design and Apply Context-Aware Access Controls Based on User Identity, Device Posture, Location, and Application Risk

SOC

A Security Operations Center (SOC) is a centralized facility responsible for monitoring and managing cybersecurity within an organization. The main objective of a SOC is to continuously observe network activity, detect potential security threats, and respond to incidents quickly. Security analysts working in the SOC analyse system logs, alerts, and network traffic to identify suspicious activities.

In the context of our project, SOC plays an important role in monitoring web application security. After identifying vulnerabilities using tools like Nessus, SOC teams can continuously

monitor systems to detect any attempt to exploit these vulnerabilities. This helps organizations maintain a secure environment and prevent unauthorized access.

SOC Cycle

The SOC cycle represents the continuous process used by security teams to detect and respond to threats. The first stage is monitoring, where network activity and system logs are continuously observed. The next stage is detection, where suspicious events or abnormal patterns are identified.

After detection, the analysis stage begins, where security analysts investigate alerts to confirm whether they represent real threats. If a threat is confirmed, the response stage is initiated to contain and eliminate the attack. Finally, the recovery stage restores affected systems and implements preventive measures to avoid similar incidents in the future.

SIEM

Security Information and Event Management (SIEM) is a technology used to collect and analyse security logs from multiple systems within an organization. These systems include servers, network devices, firewalls, and web applications. SIEM tools analyse this data and detect suspicious patterns that may indicate cyber threats.

In our project, SIEM helps monitor the vulnerabilities identified during web application security testing. By analysing security logs and events, SIEM tools generate alerts that notify security teams about potential threats. This enables organizations to respond quickly and protect their systems from cyberattacks.

SIEM Cycle

The SIEM cycle begins with data collection, where logs and security events are gathered from different systems across the network. The next step is normalization, where collected data is converted into a consistent format for analysis.

After normalization, the system performs event correlation, where related events are analysed together to detect potential threats. If suspicious activity is identified, the SIEM system generates alerts that notify security analysts. The final stage involves incident response, where the security team investigates and resolves the detected threat.

MISP

MISP (Malware Information Sharing Platform) is an open-source platform used to share threat intelligence information among organizations. It allows cybersecurity teams to exchange information about malware, vulnerabilities, and attack techniques.

Using MISP helps organizations stay updated about emerging threats and vulnerabilities. In the context of our project, MISP can help security teams understand new attack patterns and improve their ability to protect web applications.

Your College Network Information

A college network typically consists of various interconnected devices such as computers, servers, routers, and switches. These devices provide internet access and support various online services such as student portals, learning management systems, and administrative applications.

Since these systems store sensitive academic and personal information, it is important to implement strong security measures. Monitoring the network for suspicious activities helps prevent cyberattacks and ensures the safety of institutional data.

How You Think You Deploy SOC in Your College

SOC can be implemented in a college network to monitor system activities and detect cyber threats. Security tools can be used to analyse network traffic, monitor login attempts, and identify unusual behaviour.

By integrating SOC with vulnerability scanning tools like Nessus, the college can detect security weaknesses and respond quickly to potential attacks. This proactive approach helps protect student data, administrative systems, and online learning platforms from cyber threats.

Threat Intelligence

Threat intelligence refers to information that helps organizations understand potential cyber threats and attacker behaviour. It includes details about malware attacks, security vulnerabilities, and hacking techniques.

By analysing threat intelligence, organizations can identify emerging threats and improve their security strategies. This information helps security teams prepare effective defenses against cyberattacks.

Incident Response

Incident response is the process of identifying, managing, and resolving cybersecurity incidents. When a security threat or breach is detected, the incident response team investigates the issue and takes action to contain the threat.

The process usually includes detection, analysis, containment, eradication, and recovery. A well-defined incident response strategy helps organizations minimize damage and restore normal operations quickly.

Q Radar & Understanding About Tool

Q Radar is a Security Information and Event Management (SIEM) tool developed by IBM. It collects security data from multiple sources such as servers, network devices, and applications. The tool analyses this data to detect potential threats and generate security alerts.

Q Radar provides a centralized dashboard where security analysts can monitor network activity and investigate security incidents. Using tools like Q Radar helps organizations detect cyber threats more effectively and improve overall security monitoring.

CONCLUSION

Stage1:

In Stage 1, we studied different types of web application vulnerabilities such as Cross-Site Scripting, SQL Injection, Broken Authentication, and Security Misconfiguration. We analysed how these vulnerabilities affect web application security and how attackers can exploit them. Understanding these vulnerabilities helped us learn the importance of secure coding practices and proper access control mechanisms.

Stage2:

In Stage 2, we performed vulnerability analysis using the Nessus scanning tool. The Nessus scan helped us identify security weaknesses in the target system and categorize them based on severity levels. Through this stage, we learned how vulnerability scanners work and how security professionals use these tools to detect and fix potential security risks.

Stage3:

In Stage 3, we studied security monitoring concepts such as SOC, SIEM, and QRadar. These systems help organizations monitor network activities, detect cyber threats, and respond to

security incidents effectively. Integrating vulnerability analysis with SOC and SIEM monitoring improves the overall cybersecurity posture of an organization.

FUTURE SCOPE

Stage1:

Future improvements in web application security may involve implementing advanced penetration testing techniques and automated vulnerability detection systems. Organizations can also adopt secure coding frameworks to reduce security risks during application development.

Stage2:

Future work may involve using multiple vulnerability scanning tools along with Nessus to perform deeper security assessments. Combining automated scanning with manual testing techniques can help identify more complex vulnerabilities.

Stage3:

In the future, organizations may deploy advanced SOC and SIEM solutions integrated with artificial intelligence and MACHINE learning. These technologies can improve threat detection capabilities and help security teams respond to cyber threats more efficiently.

TOPICS EXPLORED

- ❖ Web Application Security
- ❖ Vulnerability Assessment
- ❖ OWASP Top 10 Vulnerabilities
- ❖ Security Operations Center (SOC)
- ❖ Security Information and Event Management (SIEM)
- ❖ Threat Intelligence and Incident Response

TOOLS EXPLORED

- ❖ Nessus Vulnerability Scanner
- ❖ Burp Suite

❖ IBM Q Radar

❖ Kali Linux

----- **THE END** -----